OpenAI for Business Security Whitepaper

ChatGPT Business Products & OpenAI API

Introduction

At OpenAI, protecting customer and user data is central to our ChatGPT business products (ChatGPT Enterprise, ChatGPT Team, and ChatGPT Edu) and the API as well as our mission as a company. We are dedicated to maintaining industry standard security and compliance for enterprise software, and to continually improving our security controls. For more information, explore our enterprise privacy FAQ page and our detailed Security Portal.

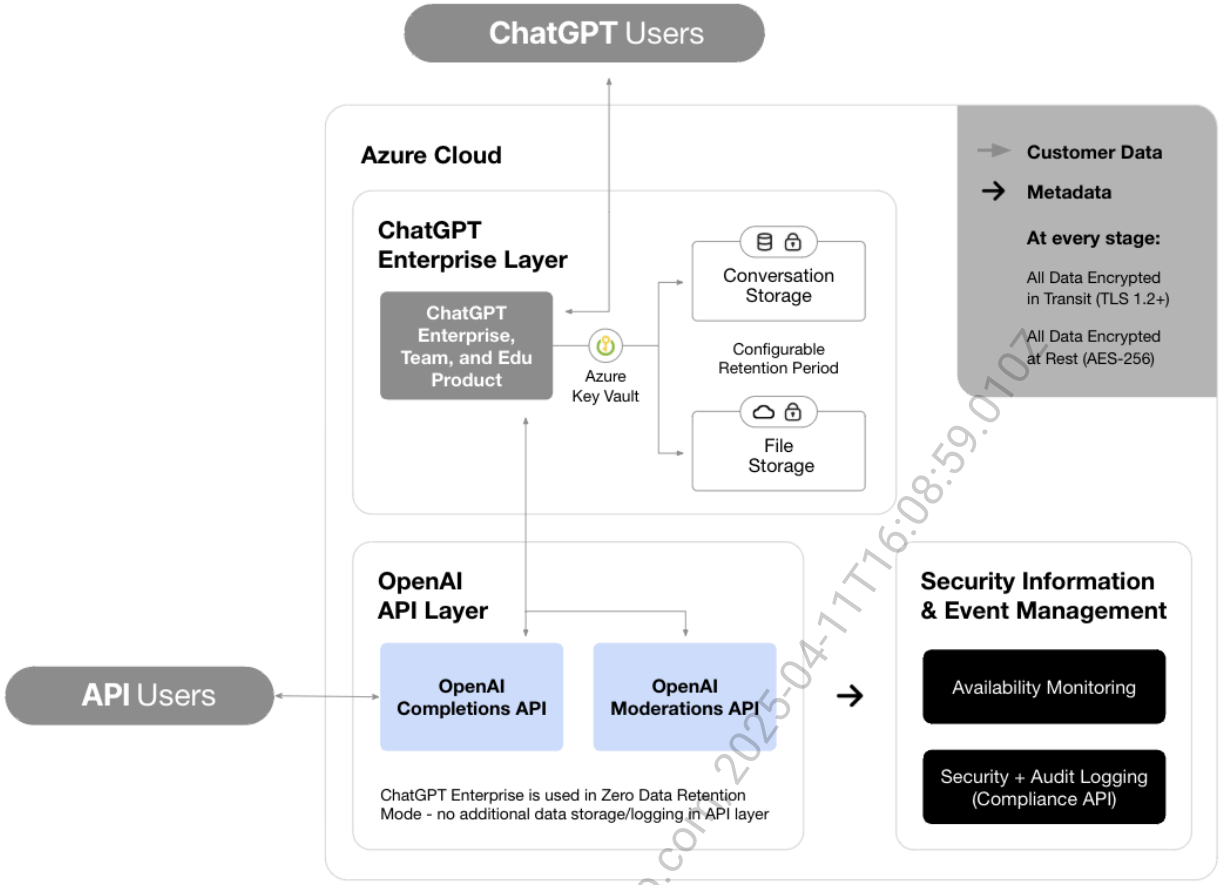
We have implemented strong security measures for ChatGPT business products and the API by employing security and compliance by design, commensurate with the use cases for these products.

ChatGPT Business Products

ChatGPT Enterprise, ChatGPT Team and ChatGPT Edu application infrastructure was built to meet security and compliance industry standards for hosted SaaS applications. ChatGPT business products are hosted on Microsoft Azure, using best practices for cloud computing security, including utilizing encryption, network controls, change controls, and access controls.

All data stored within our system utilizes industry standard encryption at rest with AES-256 and in transit using TLS 1.2 or higher. ChatGPT business plan customers have the option to authenticate via Single Sign On and utilize SCIM, giving users complete control over user provisioning. Production infrastructure has strong network and egress controls, with allowlists defining what services our clusters can communicate with. Finally, our security practices and controls are audited for SOC 2 Trust Services Criteria, confirming that they align with industry standards for security and confidentiality.

Asad Nanson, asad@cluecontrolstudio.com, 2025-04-17T16:08:59.010Z



Asad Mansoor asad@cloudcontrolstudio.com 2025-04-11T16:08:59.010Z

Data Classification

OpenAI protects customer data with enterprise-grade security and privacy controls for sensitive corporate data. Customer data includes prompts, completions, multimodal feature inputs such as audio and visual data, file uploads, user preferences, and SSO & applications configurations.

Metadata derived from system usage is distinct and used to ensure the safety and security of OpenAI's systems. This includes user ID, org ID, other internal UUIDs, email addresses, phone numbers, IP Addresses, and device information such as JA3 fingerprints. Metadata is protected with the same security controls and persists in our Security Information and Event Management (SIEM) systems to enable security analytics and support the incident response process.

Data Management

ChatGPT business products use Azure CosmosDB and Storage Accounts for data management. Access to storage accounts as well as CosmosDB is scoped to the server resources that require such access via Identity and Access Management (IAM) controls. Data is encrypted-at-rest using AES-256 and an OpenAI managed key stored in Azure KeyVault. Our infrastructure and services enforce distinct logical segregation of organizational data. Access is

governed with strong network, encryption, and access controls that are monitored to ensure only those authorized to view data within an organization are able to access this data.

By default, ChatGPT business customer data is not used for training or improvements to OpenAI's models and is only stored for the purposes of application functionality, or where required by law. We enforce this by storing these conversations in dedicated database containers that only live in ChatGPT business infrastructure that is not connected to or replicated to our training pipeline. Customer data is hosted in our infrastructure and logically segregated from other customers' data with controls and security alerting to prevent any unauthorized access, including from OpenAI employees.

Multimodal feature data storage, including voice and image inputs, are segregated from customer and user data using organization IDs and enterprise data markers in our multi-tenant Azure instance. Multimodal data inputs are subject to the same stringent controls governing other forms of enterprise data are and are never used to train our models.

Communication between OpenAI clients and our ChatGPT business products is encrypted using TLS 1.2 or higher. OpenAI recommends organizations limit and monitor access to their ChatGPT plan on their network in line with their policies and security controls. Users are only able to access their data within the customer organizational workspace that they have been added to. Access determination is based on user authentication, and application level guarantees prevent access to unauthorized data.

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-06-11 11:06:39.0102

Data Retention

ChatGPT business products store customer data only to provide critical functionality and power conversation history, search, team collaboration, and other future features. While unlimited data retention offers the ideal customer experience, we recognize that some customers may wish to configure how long sensitive data (i.e. conversations and files) is stored on our systems. Deleted customer content will be removed from our system within 30 days, regardless of the selected retention period.

User Authentication and Roles (SSO)

All users are required to authenticate to ChatGPT Enterprise and Edu via Single Sign On (SSO), using your organization's SAML 2.0 or OIDC Identity Provider (IdP). An authenticated user is issued a token associated with their identity, and this token is used for all requests made to the ChatGPT business services.

Within ChatGPT Enterprise, Team and Edu organizations, there are three roles in which a user can be assigned: Account Owner, Account Admin, and Standard Member.

User & Group Provisioning (SCIM)

The OpenAI SCIM integration allows identity providers to exchange user identity data with OpenAI, automating the provisioning and deprovisioning of user accounts in ChatGPT Enterprise and Edu workspaces based on organizational changes. Workspace owners and administrators can sync their ChatGPT business workspace with their identity provider to automatically manage user accounts and invites.

Users and groups can be provisioned via SCIM or via manual controls in the admin panels. Only SCIM-provisioned users, not manually added users, will be automatically deprovisioned based on IdP group membership.

DLP, eDiscovery & SIEM (Compliance API)

A Compliance API for ChatGPT Enterprise and Edu workspaces logs user interactions and enables workspace owners and administrators to export or delete ChatGPT conversations and files from your ChatGPT workspace. The Enterprise Compliance API supports a subset of all possible events in ChatGPT. We will continue to add support for additional endpoints. This is critical for two services:

- DLP (Data Loss Prevention): used to detect and prevent data breaches, data exfiltration, and the unauthorized use or access to sensitive information within an organization
- eDiscovery: helps in identifying, collecting, and delivering electronic information that can be used as evidence in legal cases or audits

For a list of available integrations, please refer to our Compliance APIs for Enterprise Customers page.

OpenAI API

OpenAI gives the utmost priority to securing customer data to keep our API offering safe and uphold our mission as a company. We are committed to protecting our developer community by implementing industry-leading security capabilities for our API and continually improving our security controls. For more information, refer to our Security Portal, our Enterprise Privacy page, and our API best practices.

The OpenAI API comes with the following commitments to user data security and privacy:

- **Encryption**: All data is encrypted at rest and in transit.
- **Restricted Access**: Our access to API business data stored on our systems is strictly limited to (1) authorized employees that require access for engineering support, investigating potential platform abuse, or legal compliance; and (2) specialized third-party contractors who are bound by confidentiality and security obligations, solely to review for abuse and misuse.
- **No Training**: By default, we do not train our models on API data, inputs, or outputs.

Asaf Mansour, asaf@cloudcontrolstudio.com 2025-04-17 08:59:010Z

- **Data Segregation**: Data is stringently segregated by such attributes as Organization ID in our secure Azure storage locations.
- **Data Retention**: Except for features and endpoints listed in our API documentation, OpenAI may securely retain API inputs and outputs for up to 30 days to provide the services and to identify abuse. After 30 days, API inputs and outputs are removed from our systems, unless we are legally required to retain them. Customers can request Zero Data Retention (ZDR) for eligible endpoints with a qualifying use-case.

Data Classification

OpenAI safeguards API customer data with industry best security and privacy controls for enterprise data. API customer data includes prompts, completions, file uploads, user preferences, and SSO & applications configurations.

API usage metadata is temporarily collected for fraud and abuse monitoring purposes and is distinctly marked. This includes user ID, org ID and other internal UUIDs, email addresses, phone numbers, IP Addresses, and device information such as JA3 fingerprints. API Metadata is encrypted and secured by the same security controls as other forms of customer data, persisting in our Security Information and Event Management (SIEM) systems to enable security analytics and support the incident response process (IRP).

Data Management

To ensure security of user data, all API customer data is encrypted at rest and in transit. Data is encrypted for both requests and responses, with requests sent over HTTPS using TLS 1.2 or higher. API communications are encrypted and authenticated with API keys stored using our Azure key management solutions, including an HSM (Hardware Security Module).

To maintain customer data protection aligned with industry best practices, logical segregation is implemented for all API data and metadata. Metadata associated with customer API use is segregated using a unique Organization ID in our Azure multi-tenant environment, where data is processed in multi-tenant engine clusters unless dedicated capacity is purchased. In addition, access to fine-tuned models in the API offering is restricted to the Organization ID that owns the model. Such models are not retained in any OpenAI systems once they have been deleted by an API customer.

Data Retention

Except for features and endpoints listed in our API documentation, OpenAI may securely retain API inputs and outputs for up to 30 days to provide the services and to identify abuse. After 30 days, API inputs and outputs are removed from our systems, unless we are legally required to retain them. For details on data handling, visit our Platform Docs page.

Asad Mansoor, asad@cloudcontrolstudio.com 2025-04-11 16:08:59 010Z

In our primary data store for API data, deletion is automatically triggered for any records that have reached the 30-day expiration period. In addition, any data voluntarily sent to OpenAI for fine-tuning can be deleted by our customers at their discretion. Default retention periods and deletion capabilities also differ across available OpenAI endpoints. Please reference our Default Usage Policies by Endpoint for more detail on retention schedules.

Customers can request Zero Data Retention (ZDR) for eligible endpoints if they have a qualifying use case. For ZDR customers, only metadata associated with requests are captured for security event logging and analytics purposes. ZDR customer data is not retained or persisted to any logging mechanism and exists only in memory to serve the request.

User Authentication and Roles

Ensuring the security of API keys is tantamount to API user best practices. The OpenAI API offers users API keys with distinct roles available for authentication and designed to give users oversight of API key permissions and access patterns, giving admins full visibility over their organization's API activity.

To ensure access is appropriately provisioned for user roles and use cases, API users have the ability to create API keys at a project level. Learn how to manage access controls in your Projects in this Help Center article and explore our API Keys reference guide to learn more.

Audit Logging

Audit Logging functionality allows API admins to enforce existing identity and access management policies to support enterprise organizations in meeting their transparency and auditability goals. Please reference our Help Center article or reach out to your account manager for more information.

HIPAA Support

We are able to sign Business Associate Agreements (BAAs) in support of API customers' compliance with the Health Insurance Portability and Accountability Act (HIPAA), in eligible cases. Please contact your account manager if you require a BAA.

ChatGPT Business Products & API Infrastructure Overview

Access Controls

Asad Mansoor asad@cloudcontrolstudio.com 2025-04-17 16:08:59.0 02

OpenAI uses centrally managed role-based access controls and requires employees and contractors to be authenticated prior to the use of any resources. Users' access requests for resources are validated against the user's authorized roles in Azure Active Directory and require multi-factor authentication. Elevated access requires approval, is limited to a small group of users who can request this, requires multi-factor authentication, and is time-limited.

Additional access controls include the broad use of single sign-on, device certificates for single sign-on, quarterly access reviews, and tools to defend against phishing, malware, and other risks borne from general web activity. All access is logged and audited.

Source Code Security and Deployment

All code for our services is managed via GitHub, with enforced access controls and change controls ensuring only those with an approved business need to modify this code are granted such access. Access to GitHub is governed via Single Sign On, and employees need to be on a company-issued and managed laptop in order to access the codebase. All code changes require code review, and automated tests must pass before any code is merged into the main tracking branch. Deployments to ChatGPT and API services happen via Continuous Deployment (CD) systems, and are deployed on to Azure's Managed Kubernetes Service (AKS).

Network Security

A web application firewall is deployed in front of traffic in order to protect against web application attacks and Distributed Denial of Service (DDoS) attacks on our applications.

We have strong egress controls on the infrastructure serving ChatGPT business products and API traffic. An allowlist determines what traffic can originate from these clusters, and only traffic that is required for application functionality is allowed. This allowlist is maintained as code, and changes to the allowlist require code review and approval. Ingress to the infrastructure is strictly limited to specific services and personnel that require it for the functionality of the application.

Monitoring, Logging, and Alerting

OpenAI's security team maintains an inventory of critical corporate and production assets, and consumes logs from these assets into our Security Information and Event Management (SIEM) tooling. Access to these logs are restricted to the relevant security personnel. Based on their analysis of risk and common attack patterns, our security team has automated alerts as well as manual investigation processes to monitor for suspicious activity indicative of a potential security incident.

OpenAI has extensive monitoring on the ChatGPT business products and API infrastructure, services, and user actions that alert the security and engineering teams in case of any anomalous events that indicate a potential availability incident.

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-17T16:08:59.010Z

Availability and performance alerts are triaged by the on-call engineer based on the severity of the incident. The on-call incident commander and any other relevant engineers are paged to resolve the incident. OpenAI maintains a status page which is updated to inform customers of any availability related event.

Physical Security and Environmental Control

Microsoft Azure, as the sub-service provider hosting service, has comprehensive physical security controls over data centers for in-scope systems. Access to physical datacenter facilities is tightly controlled, and includes 24/7 video surveillance along with integrated electronic access control systems to monitor datacenter sites and facilities. Datacenter location sites are strategically selected to minimize risk from a variety of factors, including floods, earthquakes, hurricanes, and other natural disasters.

Endpoint Security

Laptops and workstations are centrally managed and are secured via full disk encryption. We apply updates to employee machines on an ongoing basis and monitor employee workstations for malware and anomalous activity. We also have the ability to apply critical patches or remote wipe a machine. Wherever possible, we use two-factor authentication to further secure access to our corporate infrastructure.

Incident Response

Our Security Team has an on-call rotation that has 24/7/365 coverage and is paged in case of any potential security incident. Extensive telemetry and monitoring across both corporate and production infrastructure allows the security team to receive alerts on suspicious traffic. OpenAI maintains an Incident Response Plan (IRP) that guides how the company triages, investigates, and remediates incidents. The IRP details the categories of incidents, roles and responsibilities, as well as processes for triage, investigation, remediation, and reporting.

Bug Bounty Program

OpenAI invites security researchers, ethical hackers, and technology enthusiasts to report security issues via our Bug Bounty Program. The program offers safe harbor for good faith security testing and cash rewards for vulnerabilities based on their severity and impact. You can read more about our program and participate in our Bug Bounty Program.

Asad Mansoor asad@cloudcontrolledlic.com, 2025-04-11 16:06:59.010Z

Compliance, Audits, and Certifications

OpenAI is committed to continuous reduction of risks and improvement of security controls. Our Governance, Risk, and Compliance team collaborate across teams including Security, Legal, Engineering, and Leadership to ensure the technical controls in our products minimize risk. ChatGPT business products and the API have been audited internally by our compliance and security teams and externally by third-party auditors against the security and confidentiality Trust Services Criteria, and a SOC2 Type 2 compliance report has been issued. Our security portal allows clients to access and review our security assurance programs including audit reports, CAIQ, SIG, VSA and HECVAT questionnaires, and related documents. You may navigate to our security portal at trust.openai.com.

ChatGPT business products and the API were designed to help our customers maximize the use of their data in compliance with applicable data privacy rules and regulations. ChatGPT business products and the API support customers' compliance with applicable data privacy regulations including the EU General Data Protection Regulation (GDPR) and the California Consumer Privacy Act (CCPA).

Conclusion

At OpenAI, safeguarding customer data is prioritized by design. We are committed to upholding this trust and enhancing our security features. For any queries or concerns, please contact your Account Executive.

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-17 16:08:59 PDT